

## 6. SEGURIDAD EN EL MUNDO CONECTADO Y BLOCKCHAIN

# Eduard Lara

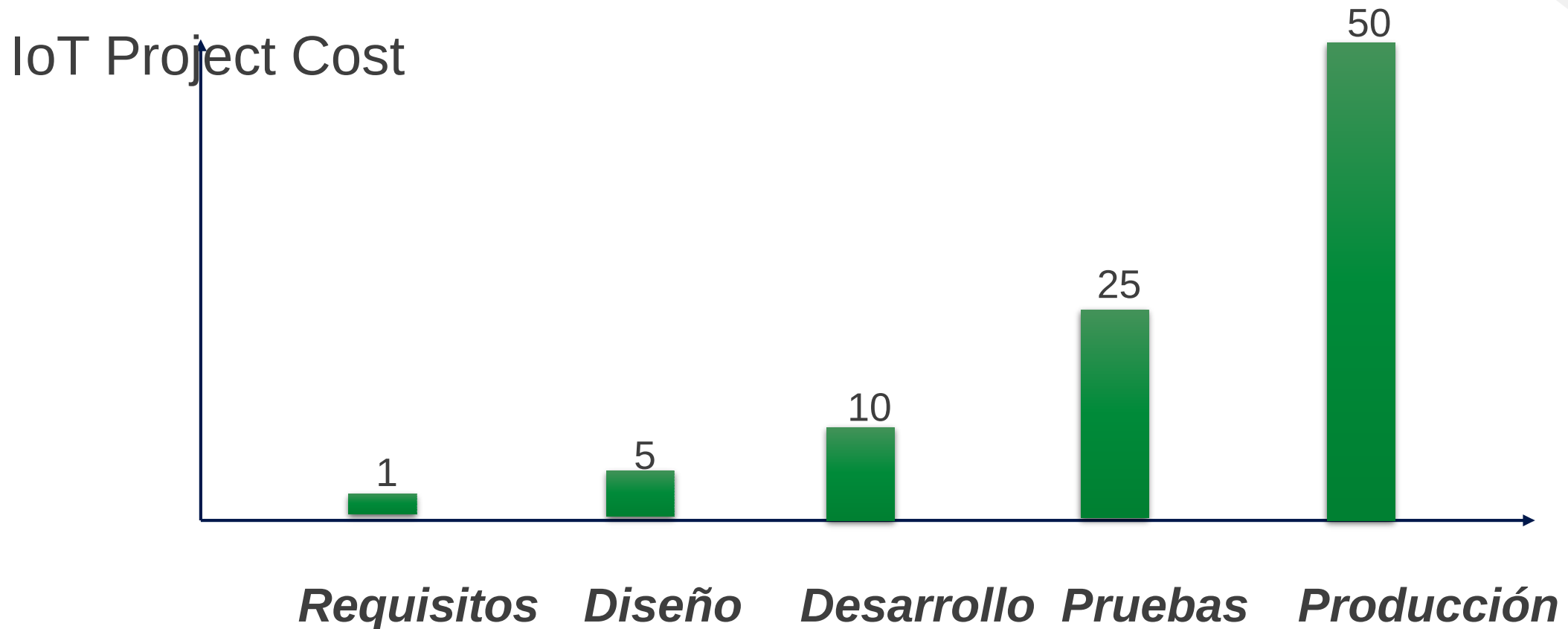
# 6.1 Impacto de la seguridad en las soluciones IoT

## Importancia de la seguridad en las soluciones IoT

- La seguridad es muy importante en cada una de las soluciones IoT
- Desde un inicio ya estemos pensando en la seguridad que vamos a aplicar en nuestra solución IoT
- Puede haber importantes diferencias en cuanto al impacto económico y temporal de todas nuestras soluciones si comenzamos desde el inicio a pensar en la seguridad en lugar de dejar para el final la aplicación de la seguridad oportuna para nuestro caso.

## 6.1 Impacto de la seguridad en las soluciones IoT

Coste de localizar y Solucionar Problemas de Seguridad en las diferentes Fases ejecución de un proyecto IoT



## 6.1 Impacto de la seguridad en las soluciones IoT

- Si en cantidades monetarias en la **fase de requisitos** tenemos un coste de una **unidad** para localizar y solucionar problemas de seguridad, si retrasamos esas decisiones de pensar en esos problemas de seguridad o cómo atajarlos a la fase de diseño multiplicaría por **5** el coste
- Si lo dejamos para la fase de **desarrollo** llegaría a **10**
- Si lo dejamos para la **fase de prueba** a **25**
- Si en la **fase de producción** nos ponemos a pensar en cómo solucionar problemas de seguridad, el coste aumentaría en 50 veces.

**El aumento del coste es exponencial cuanto más retrasemos la decisión de pensar en cómo solucionar esos problemas de seguridad**

## 6.1 Impacto de la seguridad en las soluciones IoT

### Importancia de pensar en la seguridad desde el primer momento

- La posible falta de seguridad en el escenario IoT, provoca una alta reticencia en adoptar este tipo de soluciones por la alta gerencia. Faltaran promotores o sponsors dentro de nuestra empresa que promocioe nuestros proyectos IoT, si no damos desde un inicio unas pautas de seguridad y cómo vamos a enfocar la seguridad de nuestras soluciones para que datos que sean sensibles no puedan verse vulnerados.
- Debemos pensar en la seguridad desde el primer momento, desde la toma de requisitos inicial, pensar en cómo vamos a establecer la seguridad y cómo vamos a hacer que todo nuestro dispositivo tenga una comunicación segura y no vulnerable a posibles hackeos o cualquier posible anomalía que se pueda dar.

# 6.1 Impacto de la seguridad en las soluciones IoT

## Recomendaciones

### Recomendaciones de seguridad en los dispositivos:



- 1) Las compañías deben proteger y evitar vulnerabilidades típicas como:
  - Dejarse puertos TCP/UDP abiertos,
  - Dejar las contraseñas abiertas o dejar las contraseñas por defecto que vienen en los dispositivos
  - Proteger lugares donde inyectar código como los servidores web
  - Utilizar comunicaciones no encriptadas.
- 2) Cuando el dispositivo se inicia, asegurar la integridad del software verificándolo a través de firma digital. Una entidad externa certifica que el software que tiene actualmente instalado el dispositivo y qué se está ejecutando dentro de nuestra thing, es lo que se autorizó desde un inicio. Es para que no haya una alteración del código que haga que nuestro dispositivo ejecute alguna actividad que realmente no le compete.

## 6.1 Impacto de la seguridad en las soluciones IoT

### Recomendaciones



- 3) Antes de invertir en cualquier tipo dispositivo y utilizarlo para nuestro escenario IoT, debemos evaluar las capacidades de seguridad del dispositivo y asegurar que existe la posibilidad de testear esa seguridad. Además que tenga la capacidad de aplicar actualizaciones y parches de seguridad del fabricante ante cualquier nueva vulnerabilidad aparece en el mercado
- 4) No utilizar dispositivos que no tienen soporte del fabricante. Si no hay soporte del fabricante no habrá posibilidad de nuevos parches de seguridad ante cualquier anomalía
- 5) No permitir acciones como la conectividad automática a redes WiFi abiertas, ya que tienen un claro riesgo a futuras brechas de seguridad.
- 6) Intentar encriptar la información siempre que sea posible. Normalmente se hace a través de las plataformas IoT tanto en transmisión como recepción

# 6.1 Impacto de la seguridad en las soluciones IoT

## Recomendaciones



### Recomendaciones de seguridad de red

- 1) Incluye el uso de una fuerte autenticación de usuario y mecanismos de control de acceso. En casi todas las plataformas tenemos la certificación y autenticación con X.509 y protocolos de TLS. Asegurarnos de utiliza algo similar en cuanto a la autenticación de nuestros dispositivos en la red
- 2) Las contraseñas utilizadas en la red deben ser sofisticadas para evitar que sean averiguadas a través de métodos de fuerza bruta, que van probando diferentes claves y puedan realmente romper y obtener esa contraseña.
- 3) Intentar aplicar siempre autenticación de 2 factores (2FA) que requiere:
  - El password habitual que tendremos en nuestra thing para poderlo mapear en nuestra plataforma IoT a través de la red
  - Un factor de autenticación adicional como puede ser un código aleatorio y temporal generado por ejemplo vía SMS.



## 6.1 Impacto de la seguridad en las soluciones IoT

### Recomendaciones



- 4) Utilizar protocolos seguros como IPSec o TLS/SSL
- 5) Minimizar el ancho de banda de los dispositivos a la capacidad razonable de datos generados. Si nuestros dispositivos generan un volumen de datos superior a la capacidad para la que fueron programados, puede ser indicativo de una anomalía y que el dispositivo no funciona correctamente
- 6) Implementar una red separada para nuestro escenario IoT. Detrás de un firewall. Normalmente se puede tener una VPN, que funciona gracias a un firewall y que siempre estamos monitorizando la red cuidadosamente.

Realmente la seguridad en IoT no es un problema tecnológico, es un problema cultural!! No estamos pensando desde un inicio en la seguridad. si aplicamos algunas de las alternativas de seguridad recomendadas No tendremos problemas con nuestras soluciones,

## 6.1 Impacto de la seguridad en las soluciones IoT

### Caso real falta de seguridad



- Hace poco se hackearon millones de cámaras de vigilancia que tenían la contraseña por defecto. Mantuvieron la contraseña por defecto que venían para el acceso a cámaras/things.
- Al hacerse con el control de esas cámaras, se enviaban un exceso de paquetes y de solicitudes de servicio a un servidor concreto, produciéndose ataque por denegación de servicio.
- Si hay millones de cámaras atacando a un mismo servidor lo normal es que ese servidor acabe cayendo y por tanto tengamos esa brecha de seguridad

## 6.2 Seguridad en el ciclo de vida del proyecto IoT SDLC (Software Development Life Cycle)

Además de requisitos funcionales, **analizaremos los posibles riesgos** que pueda tener nuestra solución IoT y estableceremos los requisitos relativos a seguridad.

Se deberá proveer al equipo que ejecuta el diseño las herramientas necesarias para hacerlo de manera segura y **guías de desarrollo seguro**

**Bastionado de sistemas**, es decir, configurarlo de manera segura para impedir que pueda tener funcionamientos anómalos. Se apoyan en guías de bastionado realizadas para cada producto y versión.

Toma de  
Requisitos

Diseño

Desarrollo

Pruebas

Integración

Mantenimiento

Además del diseño funcional de nuestro aplicativo, diseñaremos las medidas de seguridad que **mitiguen los riesgos detectados** en la fase anterior.  
Ej: Diseño del sistema de cifrado, de autenticación, de almacenamiento seguro...

Las **pruebas de seguridad** pueden ser estáticas o dinámicas:

- Análisis de código
- Análisis de vulnerabilidades

Con el tiempo, **aparecen vulnerabilidades** en los sistemas, que deben revisarse y actualizarse para no incurrir en riesgos innecesarios

## 6.3 Introducción al Blockchain

### ¿Qué es Blockchain?

- Una cadena de bloques es esencialmente solo un registro, un libro mayor que recoge todos los acontecimientos digitales en una red y que está distribuido o es compartido por muchas partes diferentes.
- Blockchain es un registro inmutable y permanente. Se trata de una base de datos que solo permite escritura. No se puede modificar ni borrar nada de ello, solo añadir, y todo ello bajo consenso de la mayoría de los participantes.
- Debe haber una entidad que valida cada actualización del libro mayor. Normalmente son nodos denominados **mineros** que mediante fuerza bruta computacional descifran el hash. El minero que lo descifra obtiene una recompensa, creando un nuevo bloque válido

## 6.3 Introducción al Blockchain

### Explicación grafica

1

A quiere enviar dinero a B

2

La transacción se representa en la red como un nuevo "bloque"

3

El bloque se transmite a todos los nodos de la red

6

Una vez bloque está validado y el Libro Mayor en todos los nodos está actualizado, ya puede haber esa transacción de dinero de A a B

5

El bloque valido puede añadirse a la cadena y se actualiza el libro mayor de todos los nodos de la red

4

Los mineros intentan descifrar el hash y cuando uno lo consigue la transacción es validada y se consigue el consenso. Obtiene recompensa pagada en bitcoins

## 6.3 Introducción al Blockchain

### Características del Blockchain

#### Donde se puede aplicar

- En cualquier entorno en el que haya transacciones que necesiten seguridad y confianza se va a poder aplicar blockchain

#### Problema de blockchain

- Todo este procedimiento de enviar un bloque esperar, a que se propague por la red, que el minero descifre el hash, que se vuelva a actualizar todo el libro mayor para que todos los nodos tengan de nuevo la información actualizada con todas las transacciones, va a sobrecargar el procesamiento global de la red
- Se trata de un intercambio entre seguridad de red e ineficiencia en cuanto al procesamiento en la propia red

## 6.3 Introducción al Blockchain

### Características del Blockchain

#### Que beneficios aporta Blockchain

- Ahorran tiempo. El tiempo de una transferencia internacional puede pasar de días a casi instantáneo
- Eliminar costes de intermediarios → ¿A quién puede sustituir el blockchain? Puede sustituir a todos los agentes que actualmente garantizan o certifican cualquier tipo de transacción, como bancos, notarios,... Es un sistema automático que es 100% fiable y que puede eliminar gran parte de los intermediarios que hay en toda la cadena de valor

## 6.3 Introducción al Blockchain

### Características del Blockchain

- Reducen los riesgos de Cibercrimen de fraude. Gracias al uso de esa cadena de bloques común que se sincroniza entre todos los nodos lo que se logra es que no haya nunca irreversibilidad y reversibilidad de las transacciones y no permite que nadie truque el sistema para beneficiarse. En blockchain cada nuevo bloque que se valida se incorpora a la cadena pero solamente tenemos permiso de volver a escribir un nuevo bloque, nunca vamos a poder modificar o alterar todos los bloques anteriores
- Al final incrementa la confianza tanto para cualquier tipo de escenario incluido el IoT concreto, puesto que al final es la transferencia y transacción de datos entre diferentes entidades, las things con su Gateway y con la plataforma IoT

Vamos a poder aplicar el blockchain a nuestras soluciones IoT



## 6.3 Introducción al Blockchain

**Problemas que detectaron al intentar usar Blockchain en IoT.**

**Razón de surgimiento de IOTA**

- **Micro pagos.** Los mineros una vez que son capaces de descifrar la hash tienen que obtener una recompensa por el procesamiento que han tenido que hacer. Los micropagos para la economía M2M no van a compensar el coste que tiene para los mineros esa tarea. Las comisiones de los mineros son demasiado altas → Propuesta: Eliminar los mineros. ¿Quién hace esa prueba de validez? Al no haber mineros, no hay competitividad por la recompensa y por tanto se espera que la red no incremente su complejidad. Con una pequeña prueba de validez sería suficiente y podríamos eliminar de la foto a todos los mineros para acelerar este sistema enfocado en el entorno IoT

## 6.3 Introducción al Blockchain

**Problemas que detectaron al intentar usar Blockchain en IoT.**

**Razón de surgimiento de IOTA**

- **Micro pagos.** Los mineros una vez que son capaces de descifrar la hash tienen que obtener una recompensa por el procesamiento que han tenido que hacer. Los micropagos para la economía M2M no van a compensar el coste que tiene para los mineros esa tarea. Las comisiones de los mineros son demasiado altas → Propuesta: Eliminar los mineros. ¿Quién hace esa prueba de validez? Al no haber mineros, no hay competitividad por la recompensa y por tanto se espera que la red no incremente su complejidad. Con una pequeña prueba de validez sería suficiente y podríamos eliminar de la foto a todos los mineros para acelerar este sistema enfocado en el entorno IoT

## 6.3 Introducción al Blockchain

- **Escalabilidad.** Necesitamos un sistema que pueda absorber un gran volumen de transacciones esperado de nuestro escenario IoT. Si tenemos que esperar que blockchain para cada una de las millones de transacciones de datos que producen nuestras things tenga que validar todos los componentes de la cadena por cada uno de los mineros e incorporar el nuevo bloque a la cadena, puede que haya un retraso o una latencia no asumible para nuestro escenario → Propuesta: Eliminar bloques. Cada vez que realicemos una transmisión tendremos que realizar una pequeña prueba de validez para validar las 2 transacciones anteriores a la nuestra (en lugar de tener una cadena con todos los millones de bloques que puede haber en todo el sistema blockchain)

## 6.3 Introducción al Blockchain

- **Blockchain - Libro mayor.** Una de las principales características de Blockchain es que tenemos que tener una copia completa del libro mayor en todos los dispositivos. Conforme pasa el tiempo, esta copia cada vez crece más y ocupa más espacio. Los dispositivos IoT no pueden guardar tanta información. → Propuesta: Arquitectura Directed Acyclic Graph (DAG) Significa es que en lugar de tener toda la información de nuestro libro mayor, vamos a tener una estructura que va vinculándose siempre hacia delante hacia el siguiente salto y no vamos a tener que tener guardada la documentación o el libro mayor global desde el inicio de los tiempos. Hay mucha teoría y múltiples recursos para poder hacerlo.

## 6.3 Introducción al Blockchain

- **Seguridad.** La cadena del blockchain aporta seguridad, pero ¿qué ocurre cuando aparezcan los ordenadores cuánticos que realmente van a tener una capacidad brutal de procesamiento? Van a ser una amenaza para blockchain ¿Como podemos mejorar para que las hashes no entren en peligro y no puedan ser vulnerados por alguna entidad tercera? → Propuesta: Usar un sistema trinario. Hay tal variedad de combinaciones (trillones de combinaciones) como átomos en el universo y por tanto no habría ningún sistema capaz de obtener esa clave o ese credencial, si estamos utilizando un sistema trinario



# CIBERSEGURIDAD EN IOT

ANALISIS DE AMENAZAS, RIESGOS Y VULNERABILIDADES

# Resumen y Objetivos

Dispositivos interconectados y con capacidad de toma de decisiones  
Intervención en sistemas cada vez más complejos y con operativas más críticas

Garantizar operativa e integridad de los datos

## OBJETIVOS

Definir IoT y modelar un sistema concreto

Estudio de debilidades, riesgos y amenazas

Elaborar guía con mejoras prácticas

Estudio de vulnerabilidades presentes en el sistema

Adquirir perspectiva global de un sistema IoT complejo y de la importancia de la seguridad en estos sistemas

# Definición de IOT

Concepto de IoT: interconexión de objetos entre ellos o a través de una red como Internet

Evolución tecnológica hacia sistemas IoT

- SoC, chips electrónicos, distinguir entre sensores y actuadores

- Smartphones

- Redes inalámbricas

- DIY, popularización de Arduino y Raspberry

- Proliferación de dispositivos (previsión de > 30 mil M para 2020)

Características de una IoT

- Comunicaciones

- Gestión y procesamiento de datos





# Definición de IOT

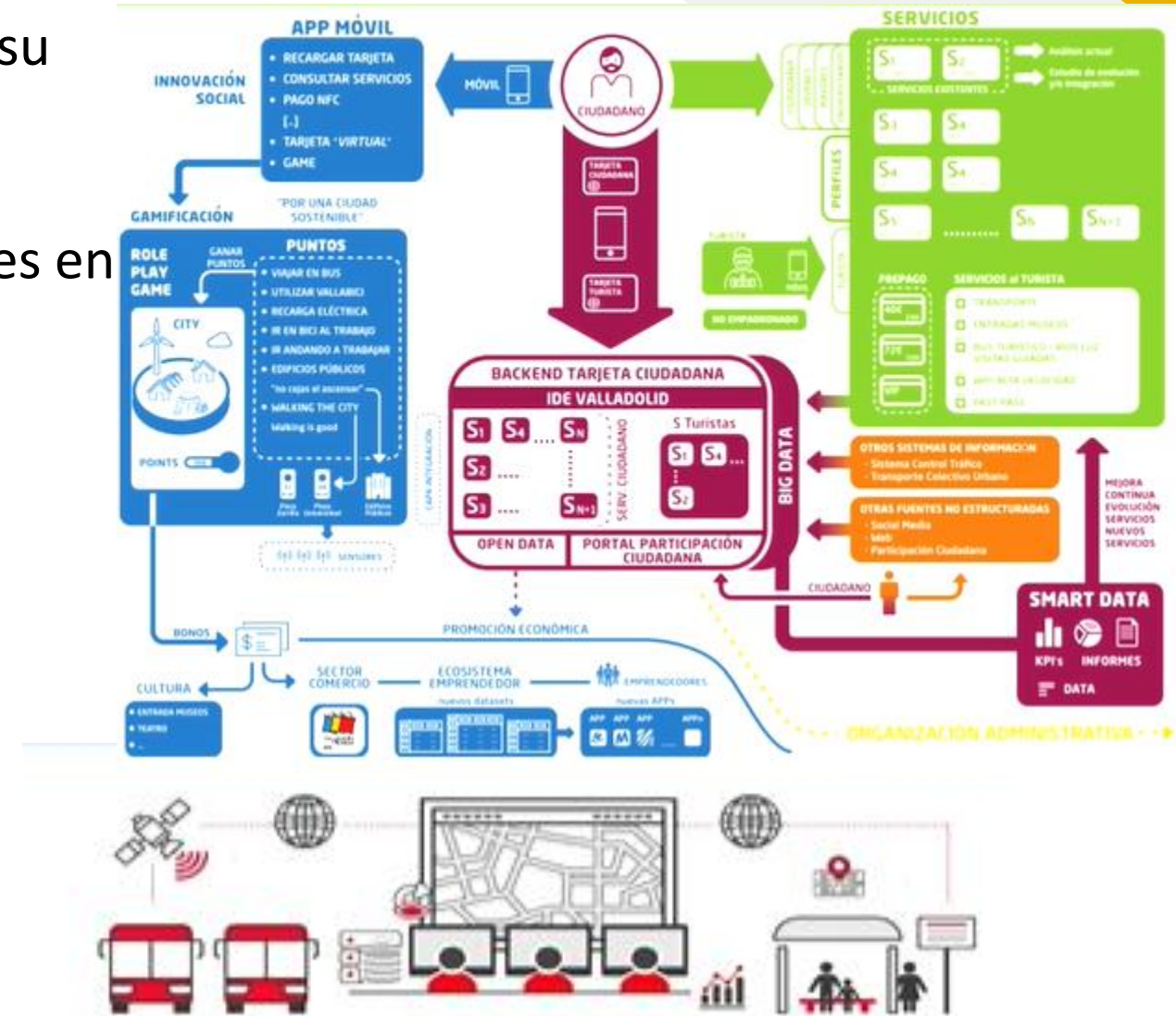
Importancia de la seguridad en IoT, debido a su proliferación suponen un objetivo para los ciberdelincuentes, es primordial reforzar la seguridad para prevenir o mitigar esos ataques en caso que prosperen

Vectores de ataques más frecuentes

Fuerza bruta con el descubrimiento de contraseñas

Denegación de servicio que impiden al sistema realizar su función o dar servicio

Acceso a un nodo de la red y obtención o interceptación de datos.



# Definición de IOT

Algunas tipologías de sistemas IoT:

Industrial IoT, IIoT, relacionado con la Industria 4.0

Smart City: proyectos muy ambiciosos en los que se digitalizan y automatizan los servicios proporcionados por una metrópoli como el transporte urbano, el préstamo de bicicletas, las bibliotecas municipales, etc..

Smart Home: HomeCinema, CastingVideo, bombillas y termostatos inteligentes

Connected car, con mejoras año tras año en el vehículo convencional y el coche automático como paradigma de estos sistemas

IoT de transportes, para la gestión de flotas de vehículos, conocer en tiempo real la ubicación de los vehículos, comunicación entre vehículo y vehículo o con el centro de control, o información en paneles para el usuario

Smart Agriculture: añaden tecnología para mejorar la eficiencia en los procesos necesarios en una explotación agrícolas como el riego automático controlando la humedad del suelo o la temperatura



## Sistemas IoT de transporte:

Han evolucionado mucho en la ultima década, se están centrando en mejor la calidad del servicio y mejorar el comfort del viajero, se ha pasado de utilizar radio para comunicar vehiculo con vehiculo a usar GSM para llamadas y datos móviles 4G para llamadas entre vehículos sobre voz IP incluso 5G y también con el centro de control

Soporte de ventas de billetes con web service, tecnología contactless como NFC del móvil o pago con tarjeta bancaria.

Evolución tecnológica: se implementan por redes inalámbricas

## Componentes de sistema IoT de transporte

Sistema de información al usuario (SIU)

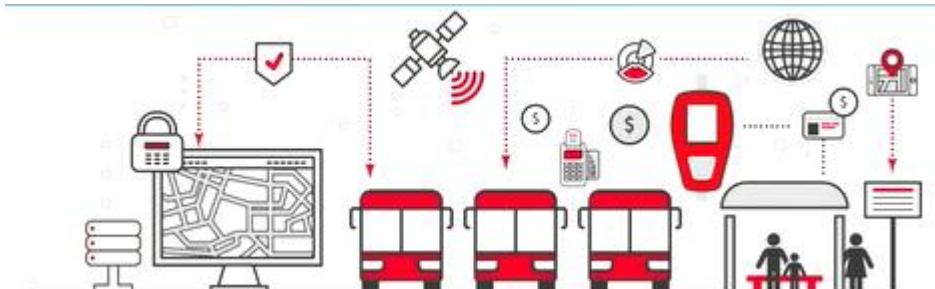
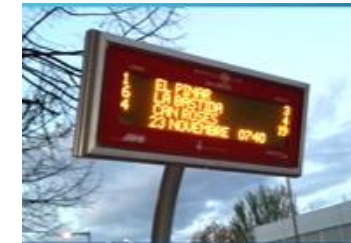
SIUV del vehiculo

SIUP de la parada

Sistema de Ayuda a la Explotacion (SAE), permite geolocalizar el vehiculo

Sistema de Validación y Venta (SVV)

Centro de control (CC)



Características más importantes

## Modelado de IOT

Red 4G IP pública

Subsistema de vehículo SIUV (Control de altavoces, dispositivos de almacenamiento masivo y contenido multimedia, SAE (gestión de la geolocalización en un mapa y envío de mensajería al CC) y SVV (soportes Mifare Classic, Desfire SAM, Android HCE, soporte papel, QR)

Subsistema de la parada (marquesina) SIUP,

Routers con firewall en vehículos u SIUP

Interconexión de subsistemas con centro de Control a través de protocolo Tansmodel + 3DES + MD5

Centro de Control opera con Windows (Server 2019,10)

Equipos embarcados operan con GNU/Linux (kernels 2.6.35 y 4.9.218)

# Estudio de amenazas y riesgos

Definición de debilidad, vulnerabilidad, amenazas y riesgo

Debilidades y ataques más importantes:

Red 4G con IP publica → Denegación de servicio de conexión a la red 4G a través de reintentos de conexión a Ips de dicha subred

Uso de protocolos abiertos → Sniffing

Tecnología Mifare Classic → Descubrimiento de claves y acceso (lectura/escritura) al contenido de la tarjeta

Tecnología EMV → Pago del servicio con tarjetas sin fondo.

Análisis de casuísticas y posibles soluciones

Ataques a la red 4G. Modificación de la topología, VPN o uso de Proxies. Operador móvil tiene cierta responsabilidad e interés por protegerse.

Intentos de fraude tecnologías SVV: Mejorar robustez del sistema SVV (diversificación de claves, migración de claves, numeración de billetes, inspecciones más frecuentes, etcètera).

# Guia de mejores practicas

## Dominios de seguridad

Personas Formación y Asignación de roles

Procedimientos:

Gestión de operaciones SGSI, gestión de actualizaciones, gestión de cambios

Seguridad en las fases SLDC: Analisis y diseño, Desarrollo e implementación,

Testing y aceptación, mantenimiento y entrega

Procedimientos corporativos de seguridad





Tecnologías

## **Guía de mejores prácticas**

Control de Acceso

Actualizaciones y aplicación de parches a software de terceros

Comunicaciones seguras

Programación de código seguro

Control anti-fraude

Revisiones de seguridad

Seguridad en todas las fases del proyecto

# Estudio de vulnerabilidades

Sistemas CVE, Bugtraq, Buscadores NVD, CVE Details (CVE/Bugtraq + CVSS)

Elementos más vulnerables del sistema:

Sistemas operativos (Windows, GNU/Linux)

- Windows 10 1111 Vulnerabilidades

- Windows Server 2019 405 Vulnerabilidades

- GNU/Linux 2.6.35.2 230 Vulnerabilidades

- GNU/Linux 4.9.218 68 Vulnerabilidades

Firmware de reouters:

- RUT950 Teltonika: 3 Vulnerabilidades, pero CVE-2017-8116 (CVSS 10.00 CRITICAL): si versión  $\leq$  00.03.265, se pueden ejecutar comandos remotos con permisos de root (ejecución remota de código + escalado de privilegios)

Protocolos y Servicios:

- SSHv2: CVE-2002-1645, en versiones para cliente de Workstations entre 3.1 y 3.2.1 se puede ejecutar código arbitrario a través de una URL larga.

Observaciones: Se solucionan fácilmente instalando otro software. Este estudio se ha de hacer



# Conclusiones y trabajo futuro

## Conclusiones

La seguridad en los sistemas IoT es primordial y se ha de tener en cuenta en todas las fases SLDC

Es inevitable introducir agujeros de seguridad por las restricciones del contrato. Se deben buscar soluciones para minimizar riesgos

Elaboración de guía de mejores prácticas y estudio de vulnerabilidades.

Adaptar diseño si resulta necesario